

DATA RETENTION AND DISPOSAL POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Data Retention and Disposal Policy
Document ID	POL-DRD-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorised by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criterion CC6.5, and GDPR Articles 5 and 17. The retention schedule is the artifact; this Policy is short by design.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 RETENTION	6
6 LEGAL HOLD.....	6
7 DISPOSAL	7
8 RECORDS.....	7
9 EXCEPTIONS	7
10 REFERENCE.....	7
11 DOCUMENT POLICY HISTORY.....	7

1 Overview and Purpose

PromptHalo Technologies (“the Company”) keeps information for as long as it has a reason to and then disposes of it. This Policy says how that decision is made and how disposal is evidenced.

The retention periods themselves live in a schedule rather than in this document, so that a period can change without amending a policy.

2 Scope

This Policy covers Company and client information wherever it is held, and any device or media that has held it.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party authorizes disposal of Confidential or Restricted information before it is carried out. [SOC 2: CC6.5]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Cryptographic erasure** — rendering information unrecoverable by destroying the keys that protect it and recording that destruction.
5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
6. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]

7. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
8. **Retention schedule** — the record of how long each category of information is kept and on what basis.
9. **Sanitization** — rendering information on media irrecoverable before the media leaves Company control or is reused.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
12. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Retention

1. Each category of information has a retention period and a basis — a client agreement, a legal requirement, or a Company decision — recorded in the retention schedule. [SOC 2: CC6.5 · GDPR Art. 5(1)(e)]
2. Client information is retained for the period the client agreement specifies and returned or deleted at the end of the engagement, with the action recorded. [SOC 2: CC6.5 · GDPR Art. 17]
3. Where information is subject to a deletion commitment, backups and snapshots holding it are identified and the retention that applies to them is stated honestly to the client rather than described as immediate. [SOC 2: CC6.5 · GDPR Art. 17]
4. The schedule is reviewed annually and whenever a client agreement introduces a different period. [SOC 2: CC6.5]

6 Legal Hold

A legal hold suspends disposal. It is short but it must exist, because the retention schedule otherwise deletes on time and that becomes the problem.

1. Where the Company becomes aware of actual or anticipated litigation, a regulatory investigation, or a client request to preserve, the Accountable Party places a hold on the information concerned. The hold names what is preserved, why, and who imposed it, and is recorded on the same day. [SOC 2: CC6.5, CC2.1]
2. Information under hold is not disposed of even where its retention period has expired, and automated deletion is suspended for it. The hold overrides the schedule until it is lifted. [SOC 2: CC6.5]
3. A hold is lifted in writing by the person who imposed it, and normal retention resumes from that point. Holds are reviewed at the annual retention review so that one does not persist by inertia. [SOC 2: CC6.5]

7 Disposal

Disposal of Confidential or Restricted information is authorized before it is carried out and recorded afterwards. [SOC 2: CC6.5]

1. Media and devices that have held Company or client information are sanitized or destroyed before disposal, reassignment or return, and the action is recorded. Because work happens in cloud services rather than on local disks, this arises rarely — which is the point. [SOC 2: CC6.5 · HIPAA §164.310(d)(2)]
2. Cloud storage disposal relies on the provider's deletion mechanisms, or on cryptographic erasure where the Company holds the keys, rather than on a physical process the Company does not perform. [SOC 2: CC6.5]
3. A disposal register records each action with its classification, retention basis and evidence, and holds any vendor destruction certificates. It is reconciled against the asset inventory so that an asset marked disposed is confirmed as gone. [SOC 2: CC6.5, CC2.1]

8 Records

1. The retention schedule with periods and bases. [SOC 2: CC6.5]
2. The disposal registers with authorizations and evidence. [SOC 2: CC6.5]
3. Deletion confirmations at the end of engagements. [SOC 2: CC6.5]

9 Exceptions

Where information cannot be disposed of when its period ends — a legal hold, or a backup that cannot be selectively purged — the position is recorded by the Accountable Party with the reason and a review date.

10 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.1, CC6.5]
2. POL-DCL-001 Data Classification Policy [SOC 2: CC2.1]
3. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
4. POL-ENC-001 Encryption Policy [SOC 2: CC6.7]
5. POL-AM-001 Asset Management Policy [SOC 2: CC2.1]
6. EU General Data Protection Regulation, Articles 5 and 17

11 Document Policy History

Version	Date	Description
---------	------	-------------